

Cirque Corporation

Internal Audit Procedure

Document ID: IS-CIRQ-PR-023-G

Category: ISMS Support Process

Division: Procedure

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: Executive Committee

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to define the process for conducting planned and systematic internal audits of Cirque's Information Security Management System (ISMS). These audits ensure that the ISMS:

- Conforms to the requirements of ISO/IEC 27001:2022.
- Conforms to Cirque's own established requirements for its ISMS.
- Is effectively implemented and maintained.
- Is performing as intended.

This procedure ensures that internal audits are conducted objectively and independently to provide valuable input for management review and continual improvement of the ISMS.

****2. Scope****

2. Scope

This procedure applies to all internal audits conducted on Cirque's ISMS processes, controls, and areas within the defined ISMS scope, across all global operations (US, Taipei, China).

****3. Roles and Responsibilities****

3. Roles and Responsibilities

- ****Executive Committee:**** Approves the annual internal audit program and ensures the independence and competence of auditors.
- ****ISMS Owner (e.g., Information Security Officer/IT Manager):**** Oversees the internal audit program, ensures audits are conducted as planned, and facilitates the resolution of nonconformities.
- ****Internal Auditor(s):**** Conducts audits objectively and impartially, prepares audit reports, and verifies the effectiveness of corrective actions. Auditors must be competent and independent of the area being audited.
- ****Auditee/Process Owner:**** Provides necessary information and access to auditors, and is responsible for implementing agreed-upon corrective actions for identified nonconformities.

****4. Procedure****

4. Procedure

- **4.1. Audit Program Planning**** a. ****Frequency:**** Annually. b. ****Responsible:**** ISMS Owner. c. ****Steps:**** 1. Develop an annual internal audit program based on the status and importance of the processes concerned, changes affecting the organization, and the results of previous audits. 2. The program shall define the scope, frequency, methods, responsibilities, and reporting requirements for each audit. 3. Ensure that the entire scope of the ISMS is covered within a defined audit cycle (e.g., every 1-3 years). 4. Obtain Executive Committee

approval for the annual audit program.

****4.2. Individual Audit Planning**** a. ****Frequency:**** Prior to each

scheduled audit. b. ****Responsible:**** Internal Auditor(s). c.

****Steps:**** 1. Define the specific objectives and scope of the individual audit (e.g., audit of Access Control Policy implementation). 2. Identify the relevant audit criteria (e.g., ISO 27001 clauses, Cirque policies and procedures, legal/contractual requirements). 3. Select competent and independent auditors for the specific audit. Independence means the auditor should not audit their own work. 4. Develop an audit plan including: * Audit team members. * Audit schedule (dates, times). * Areas/departments to be audited. * Key documents to review. * Personnel to interview. 5. Communicate the audit plan to the auditee/process owner in advance.

****4.3. Conducting the Audit**** a. ****Frequency:**** As per audit schedule.

b. ****Responsible:**** Internal Auditor(s). c. ****Steps:**** 1. ****Opening Meeting:**** Conduct an opening meeting with the auditee to confirm the audit plan, explain the audit process, and address any questions. 2.

****Information Gathering:**** Collect objective evidence by: * Reviewing documented information (policies, procedures, records, logs, IS-CIRQ-PR-006-G: Document Control Procedure). * Interviewing personnel. * Observing processes and activities. * Examining technical configurations and tools. 3. ****Evidence Evaluation:**** Evaluate collected evidence against the audit criteria. 4. ****Identify Findings:**** Document all findings, including: * ****Conformities:**** Areas where the ISMS effectively meets requirements. * ****Nonconformities:**** Deviations from ISO 27001 requirements or Cirque's own ISMS requirements. (Identify major/minor as per audit judgment). * ****Observations/Opportunities for Improvement (OFIs):**** Areas that are not nonconformities but could be improved. 5. ****Closing Meeting:**** Conduct a closing meeting with the

auditee to present the audit findings, ensure clarity, and agree on the next steps.

****4.4. Audit Reporting**** a. ****Frequency:**** Within a specified timeframe (e.g., 5-10 business days) after the audit. b. ****Responsible:**** Internal Auditor(s). c. ****Steps:**** 1. Prepare a formal Internal Audit Report using the IS-CIRQ-F-006-G: Internal Audit Report Template. 2. The report shall include: * Audit objectives and scope. * Audit criteria. * Dates and locations of the audit. * Audit team members and auditees. * Summary of findings. * Details of identified nonconformities, observations, and opportunities for improvement. * Evidence supporting each finding. 3. Submit the draft report to the auditee for factual accuracy review. 4. Issue the final audit report to the auditee, ISMS Owner, and relevant management.

****4.5. Follow-up and Corrective Actions**** a. ****Frequency:**** Ongoing until nonconformities are closed. b. ****Responsible:**** Auditee/Process Owner (for implementing actions), ISMS Owner (for oversight), Internal Auditor(s) (for verification). c. ****Steps:**** 1. For each identified nonconformity, the auditee/process owner shall initiate a corrective action request (CAR) as per IS-CIRQ-PR-025-G: Corrective Action Procedure. 2. The auditee is responsible for determining the root cause of the nonconformity, developing a corrective action plan (including timelines), and implementing the actions. 3. The Internal Auditor(s) (or a designated follow-up auditor) shall verify the implementation and effectiveness of the corrective actions within the agreed-upon timeframe. 4. Once verified as effective, the nonconformity is formally closed. 5. Maintain records of all corrective actions taken.

****5. Documentation****

5. Documentation

- Annual Internal Audit Program.
- Individual Audit Plans.
- Audit Checklists/Work Papers.
- Evidence collected during the audit.
- IS-CIRQ-F-006-G: Internal Audit Report Template (completed reports).
- Corrective Action Requests (CARs) and their closure records.
- Records of auditor competence and training.

****6. Related Documents****

6. Related Documents

- IS-CIRQ-P-021-G: Monitoring, Measurement, Analysis, and Evaluation Policy
- IS-CIRQ-F-006-G: Internal Audit Report Template
- IS-CIRQ-P-023-G: Nonconformity and Corrective Action Policy
- IS-CIRQ-PR-025-G: Corrective Action Procedure
- IS-CIRQ-F-008-G: Corrective Action Request (CAR) Form
- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-PR-006-G: Document Control Procedure
- ISO/IEC 27001:2022 Standard (external reference)
- ISO 19011: Guidelines for auditing management systems (external reference)

****7. Review****

7. Review

This procedure will be reviewed at least annually, or sooner if there are significant changes to Cirque\'s ISMS, audit requirements, or regulatory landscape.